



Laporan Insiden 2 — Serangan Kredensial & Akses Tidak Sah (Brute-Force RDP)



LAPORAN INSIDEN KEAMANAN — RAHASIA INTERNAL

ID Insiden: IR-2026-002

Klasifikasi: Internal / Lingkungan Lab

Status: Ditutup (Terdeteksi & Ter-eskalasi)

Metadata Insiden

Atribut	Detail
ID Insiden	IR-2026-002
Judul	Serangan Brute-Force RDP yang berujung Akses Tidak Sah
Tanggal Kejadian	11 Juli 2026, 14:12–14:28 WIB
Analisis	JEREMIAH MARK
Klasifikasi	Internal / Lab
Tingkat Keparahan	Sedang–Tinggi
Status Deteksi	TERDETEKSI (ter-eskalasi ke analisis)
Teknik MITRE ATT&CK	T1110 (Brute Force), T1078 (Valid Accounts), T1021.001 (Remote Desktop Protocol)
Sumber Serangan	192.168.56.10
Target	192.168.56.101 (DESKTOP-JR9CSOT, port 3389)
Status Insiden	Ditutup

1. Ringkasan Eksekutif

Pada 11 Juli 2026, terdeteksi upaya serangan *brute-force* terhadap layanan Remote Desktop Protocol (RDP) di host target **192.168.56.101** (port 3389).

Serangan berasal dari `192.168.56.10` menggunakan perkakas `xfreerdp`, yang secara berulang mencoba mengautentikasi akun `analyst` dengan daftar kata sandi.

Serangan ini memicu 20 kali kegagalan logon (Event ID 4625) yang berhasil dikorelasikan oleh Wazuh menjadi peringatan agregat, serta memicu penguncian akun (Account Lockout, Event ID 4740) karena melampaui ambang batas 10 percobaan gagal yang berlaku di Windows 11 target.

Berbeda dengan Laporan Insiden 1 (yang merupakan blind spot / tidak terdeteksi), serangan ini **berhasil terdeteksi dan ter-eskalasi**. Namun, penyerang pada akhirnya **berhasil masuk** menggunakan kredensial yang valid — dikonfirmasi oleh Event ID 4624 (logon berhasil). Dengan demikian dampaknya tergolong tinggi: kredensial valid terbukti bocor dan akses jarak jauh berhasil diperoleh.

2. Analisis Teknis

2.1 Kronologi Serangan

Tahap	Peristiwa	Bukti (Event / Rule)
Brute-force	20 percobaan logon gagal terhadap akun <code>analyst</code> via RDP	Event 4625 — Wazuh rule r60122 (Level 5)
Korelasi	Wazuh mengagregasi banyak kegagalan menjadi satu peringatan	"Multiple Windows Logon Failures" — r60204 (Level 10)
Penguncian akun	Akun <code>analyst</code> terkunci setelah melewati ambang 10 percobaan	Event 4740 — r60115 (Level 9)
Breach	Logon jarak jauh berhasil dengan kredensial valid	Event 4624 — r92657 (Level 6), "Successful Remote Logon Detected"

2.2 Detail Teknis

- **Teknik utama:** T1110 (Brute Force) — percobaan kata sandi berulang; dilanjutkan T1078 (Valid Accounts) — penggunaan kredensial sah yang berhasil ditebak; melalui vektor T1021.001 (RDP).
- **Kredensial yang dikompromikan:** akun `analyst` (kata sandi valid dikonfirmasi berhasil digunakan).

- **Waktu breach:** logon berhasil tercatat pada 14:26:24 WIB, setelah percobaan awal sekitar 14:12 WIB.
- **Indikasi Pass-the-Hash / NTLM:** Event 4624 breach tercatat menggunakan autentikasi NTLM, yang membuka kemungkinan teknik *pass-the-hash*. Ini perlu diinvestigasi lebih lanjut pada insiden nyata.

2.3 Catatan Kejujuran Analitis (Severity)

Peringatan yang terpicu berada pada level r60204 (L10), r60115 (L9), dan r92657 (L6). Berdasarkan skala keparahan Wazuh (Rendah 0–6, Sedang 7–11, Tinggi 12–14, Kritis 15+), ketiganya tergolong **Sedang hingga Rendah**, bukan Tinggi murni.

Untuk menaikkan deteksi brute-force ke level Tinggi ($\geq$ L12) diperlukan *custom rule* korelasi yang akan dibangun pada tahap SOC-011b. Perlu dicatat pula: filter `subStatus 0xC0000234` (kode status khusus akun terkunci) menghasilkan 0 hit pada pencarian — penguncian akun tetap terbukti secara sah melalui Event 4740, bukan melalui subStatus.

2.4 Indikator Kompromi (IoC)

Jenis	Nilai	Keterangan
Alamat IP sumber	192.168.56.10	Host penyerang (Ubuntu, xfreerdp)
Akun target	analyst	Akun yang dibrute-force dan akhirnya dikompromikan
Port / Layanan	3389 / RDP	Vektor serangan
Metode autentikasi	NTLM	Berpotensi pass-the-hash

3. Rekomendasi Mitigasi

1. **Bangun custom rule korelasi** yang menaikkan banyak kegagalan logon berturut-turut ke level Tinggi ($\geq$ L12), sehingga brute-force ter-eskalasi dengan prioritas yang tepat (rencana SOC-011b).
2. **Terapkan MFA dan Network Level Authentication (NLA)** pada seluruh akses RDP, agar kredensial saja tidak cukup untuk masuk.
3. **Batasi RDP di tingkat jaringan** — jangan mengekspos port 3389 secara langsung; wajibkan akses melalui VPN atau *jump host*.

4. **Terapkan kebijakan penguncian akun (account lockout) beserta alerting** khusus pada Event 4740, agar setiap penguncian langsung ditinjau analis.
 5. **Deteksi anomali NTLM / pass-the-hash** dan nonaktifkan NTLM di tempat yang memungkinkan, untuk menutup vektor logon berbasis hash.
-